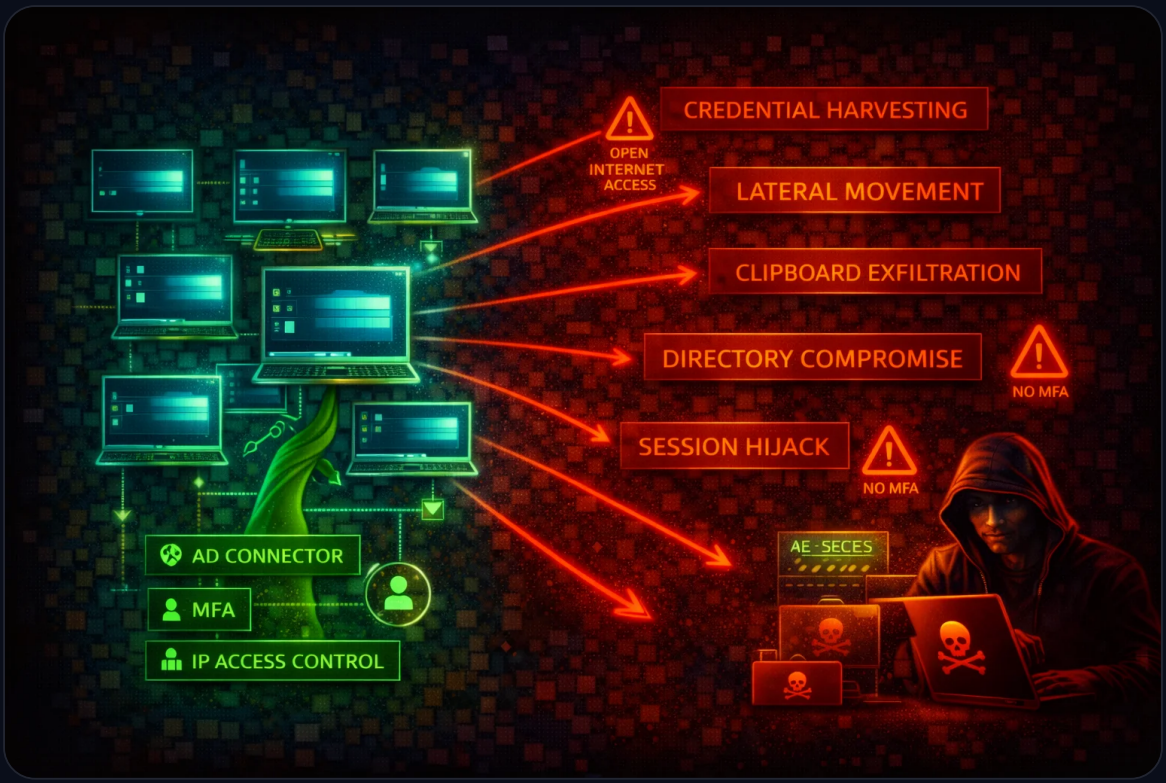

Amazon WorkSpaces Security

COMPUTE

Amazon WorkSpaces is a managed Desktop-as-a-Service (DaaS) provisioning cloud-based Windows or Linux virtual desktops. A compromised WorkSpace gives an attacker a foothold inside the customer VPC with AD-joined credentials, network access to internal resources, and clipboard/drive exfiltration paths.

HIGH	Per-Directory	PCoIP/DCV	AD Auth
Risk Level	Scope	Protocols	Authentication

📋 Service Overview

Virtual Desktop Environment

Each WorkSpace is associated with a directory (AWS Managed Microsoft AD, AD Connector, or Simple AD) and runs inside a customer VPC. Supports clipboard redirection, drive redirection, USB redirection, and local printing.

Attack note: WorkSpaces are full virtual desktops with persistent storage. A compromised WorkSpace gives a foothold inside the VPC with AD credentials, often overlooked in security monitoring.

Authentication and Access

The directory backing WorkSpaces is the single authentication plane. Clients connect via native apps or web browser. Without IP access control groups and MFA, WorkSpaces can be accessed from any IP with valid AD credentials.

Attack note: Compromising the directory grants access to all WorkSpaces. Without RADIUS MFA, stolen AD credentials alone provide full desktop access.

Security Risk Assessment

7.5

Risk Score

WorkSpaces provide full desktop environments inside the VPC with AD credentials. Clipboard and drive redirection create data exfiltration channels. Without IP access control groups and MFA, WorkSpaces can be accessed from any IP. WorkSpaces run on managed compute not visible in EC2 console.

⚔️ Attack Vectors

Initial Access & Credential Abuse

- Credential stuffing against Active Directory
- No MFA enforcement (RADIUS not configured by default)
- No IP access control (accepts all public IPs)
- Phishing for WorkSpace registration codes
- WorkSpaces Web access abuse from unmanaged devices

Post-Compromise & Lateral Movement

- VPC network pivoting from compromised WorkSpace
- Clipboard exfiltration (two-way, enabled by default)
- Drive redirection data theft to local filesystem
- AD credential harvesting (Mimikatz, Rubeus)
- Persistence via D: drive survives rebuilds

⚠️ Misconfigurations

Access Control Gaps

- No IP access control groups configured (default)
- MFA not enabled (RADIUS not configured by default)
- Web Access enabled without need
- Overly permissive outbound security groups
- Unrestricted device types (all allowed by default)

Data Protection Gaps

- Clipboard redirection left enabled (two-way default)
- Drive redirection not disabled
- Root volume not encrypted (not default)
- No user volume backup strategy
- ALWAYS_ON running mode without justification

🔍 Enumeration

List All WorkSpaces

```
aws workspaces describe-workspaces
```

List Registered Directories

```
aws workspaces describe-workspace-directories
```

Check Connection Status

```
aws workspaces describe-workspaces-connection-status
```

List IP Access Control Groups

```
aws workspaces describe-ip-groups
```

List WorkSpaces Pools

```
aws workspaces describe-workspaces-pools
```

📈 Privilege Escalation

IAM-Level Escalation

- CreateWorkspaces with AD admin credentials for VPC foothold
- ModifyWorkspaceProperties to upgrade compute resources
- ModifyWorkspaceCreationProperties to weaken security
- ModifyWorkspaceAccessProperties to re-enable device types
- RebuildWorkspaces abuse (user volume persistence)

AD-Level Escalation

- Compromised Windows WorkSpace runs AD attack tools
- BloodHound, Rubeus, Mimikatz against the domain
- Escalate from single desktop to domain admin
- Kerberoasting from WorkSpace for service tickets
- Pass-the-hash from cached AD credentials

🔗 Persistence

WorkSpace-Level

- Place payloads on D: drive (survives rebuild snapshots)
- Scheduled tasks for persistent execution
- Startup scripts on user profile
- Maintain AD credential cache for re-access
- Registry modifications for auto-run

Infrastructure-Level

- Create additional WorkSpaces as backup access
- Maintain clipboard/drive exfiltration channels
- Modify security groups for persistent network access
- Keep VPC-level access for lateral movement
- Abuse AUTO_STOP mode timing for stealth

🛡️ Detection

CloudTrail Events

- CreateWorkspaces - new WorkSpace created
- TerminateWorkspaces - WorkSpace terminated
- ModifyWorkspaceProperties - properties changed
- ModifyWorkspaceAccessProperties - access changed
- RebuildWorkspaces - WorkSpace rebuilt

Behavioral Indicators

- Connections from unexpected IP addresses
- Multiple failed AD authentication attempts
- Unusual connection patterns or times
- VPC flow logs showing lateral movement
- Clipboard/drive transfer anomalies

💻 Exploitation Commands

Create Rogue WorkSpace

```
aws workspaces create-workspaces \
  --workspaces
DirectoryId=d-1234567890,UserName=attacker,BundleId=wsb-XXXXX
```

Re-enable Web Access

```
aws workspaces modify-workspace-access-properties \
  --resource-id d-1234567890 \
  --workspace-access-properties DeviceTypeWeb=ALLOW
```

Rebuild WorkSpace (Preserves User Volume)

```
aws workspaces rebuild-workspaces \
  --rebuild-workspace-requests WorkspaceId=ws-abc123def
```

Modify Running Mode

```
aws workspaces modify-workspace-properties \
  --workspace-id ws-abc123def \
  --workspace-properties RunningMode=ALWAYS_ON
```

📜 Policy Examples

✗ Dangerous - Full WorkSpaces Admin

```
{
  "Effect": "Allow",
  "Action": "workspaces:*",
  "Resource": "*"
}
```

Full control including creating rogue WorkSpaces, disabling security controls, and terminating legitimate ones

✓ Secure - Read-Only Monitoring

```
{
  "Effect": "Allow",
  "Action": [
    "workspaces:DescribeWorkspaces",
    "workspaces:DescribeWorkspaceDirectories",
    "workspaces:DescribeIpGroups"
  ],
  "Resource": "*"
}
```

Read-only access for monitoring and auditing. Cannot create, modify, or terminate WorkSpaces.

Defense Recommendations

Enforce IP Access Control Groups

Restrict WorkSpace access to known corporate IP ranges or VPN egress IPs.

```
aws workspaces create-ip-group \
  --group-name "CorporateVPN" \
  --user-rules "ipRule=203.0.113.0/24,ruleDesc=Corp VPN"
```

Enable RADIUS MFA

Configure RADIUS-based multi-factor authentication on the directory for all WorkSpace logins.

Disable Clipboard and Drive Redirection

Use Group Policy (Windows) or DCV config (Linux) to disable or restrict clipboard and drive redirection.

Restrict Device Types

Disable unnecessary device types (especially Web Access).

```
aws workspaces modify-workspace-access-properties \
  --resource-id d-1234567890 \
  --workspace-access-properties
DeviceTypeWeb=DENY,DeviceTypeIos=DENY
```

Enable Encryption at Rest

Encrypt both root and user volumes with KMS at creation time (cannot be enabled later).

Use AUTO_STOP Running Mode

Reduce attack window during idle periods.

```
aws workspaces modify-workspace-properties \
  --workspace-id ws-abc123 \
  --workspace-properties
RunningMode=AUTO_STOP,RunningModeAutoStopTimeoutInMinut
es=60
```


Always obtain proper authorization before testing